

A365 Gateway

Platform-neutral product specification | 01 October 2026

The Gateway is a middle layer between independently hosted AI agents and Microsoft Agent 365. It registers agents, accepts and forwards telemetry, and exposes content checks through Microsoft Purview and Prompt Shields. External agents keep their own hosting, models and business logic.

External agent Any supported host or model Calls Gateway APIs	Gateway Admin UI + APIs Identity binding, checks, delivery	Microsoft integrations Agent 365 / Entra Purview / Prompt Shields
--	---	--

1. The required product

Capability	Required outcome
Agent registration	Create or reuse an appropriate blueprint, create the distinct agent identity, and complete authorized Agent 365 registration.
Telemetry	Accept supported activity and interaction events; forward them to Agent 365 through Microsoft's supported OpenTelemetry integration.
Purview	Process applicable content through Microsoft Purview and return the actual policy outcome and processing state.
Prompt Shields	Offer independent prompt attack checks through the supported service API/SDK, without requiring the agent's model to be hosted by Microsoft.
Administration	Provide straightforward registration, one-time key handoff, feature settings, operation status and actionable errors.

2. Hosting is not a product dependency

No particular cloud, database engine, message broker, object store, orchestrator or hosted telemetry intermediary is required by this specification. Those are replaceable implementation choices, not obligations imposed on an external agent.

Intentional boundary: Microsoft identity and service APIs are product integrations. They do not require the Gateway itself to run in Microsoft's cloud. Local hosting does not make real tenant services available offline.

Not this product: an LLM host, model proxy, agent framework, generic integration platform, or enterprise infrastructure provisioning system.

This document states intended behavior, not current implementation status or proof of completion.

Connect an agent

One registration, one bound identity, one controlled credential lifecycle

3. Registration journey

Step	Required behavior
1. Sign in	Authenticate the tenant administrator. Enforce tenant, user and role permissions in the API, not only by hiding UI controls.
2. Review	Collect agent details, select a compatible existing blueprint or create a new one, and review telemetry and protection choices. Explain shared-policy impact.
3. Accept and hand off	Persist the registration and recovery identity. Return the endpoint, external agent ID and one-time Gateway key immediately, before Registry completion. Require acknowledgment that the key has been saved.
4. Register	Create and bind the distinct Entra agent identity and complete the Agent 365 Registry action with the required delegated administrator authority. Do not substitute an app-only identity for a user-only operation.
5. Verify	Read back the intended identity and registration before reporting Active. Show pending, failed and unknown outcomes accurately.
6. Manage	Allow authorized access enable/disable, feature changes, key replacement/revocation and operation inspection. Removing the Gateway registration preserves linked Microsoft resources unless separately authorized.

4. Identity and credential rules

- Each registration binds its tenant, external agent ID, blueprint and distinct child agent identity. Multiple registrations may share a blueprint; they do not share an unrestricted Gateway key.
- The external agent receives a Gateway credential, never the Gateway's Microsoft credentials. A valid key for one registration cannot be used with another registration's identifier.
- Display a new key once; retain only a non-reversible verifier and lifecycle metadata. Lost keys require replacement, not recovery of the original clear value. Keep keys out of URLs and logs.
- Use least-privilege service credentials for background provider access. A human administrator's password is not application runtime configuration.

5. A small, task-focused administration UI

Provide getting-started guidance, an agent list/detail view, registration and key handoff, protection settings, and operation history. Show the next permitted action without forcing users through deployment internals. Preserve reviewed choices; missing prerequisites must not silently switch a requested protection off.

Unknown is not failed or safe to repeat. After a lost response, recover the original operation by its retained identifier and read back the provider outcome. Never create another agent or registration merely to make the screen appear complete.

Evaluate, then send

The external agent owns the model call; the Gateway owns its API decisions

6. Core external-agent APIs

Use authenticated HTTPS APIs, with the Gateway key bound to the supplied external agent ID. Mutations carry an idempotency key; responses carry safe correlation and processing identifiers.

Operation and responsibility

POST /api/v1/prompts:evaluate

Evaluate the exact prompt. Return a valid allow and bound, expiring receipt, or a clear block/error.

POST /api/v1/agent-activities

Accept, validate and sanitize supported activity events; track processing for the authenticated agent.

POST /api/v1/ai-interactions

Accept the matching prompt/response and evaluation receipt; run applicable content processing and telemetry delivery.

Administrative APIs manage registrations, credentials, settings and operations. Detailed request schemas remain in the repository API contract; this specification defines required behavior.

7. The normal interaction

1. **Evaluate before every model call.** The client submits the exact prompt and interaction context. It does not infer protection settings from a cached local flag.
2. **Proceed only on a valid allow.** Require a successful response with **allowed: true**, a nonempty receipt and a valid future expiry. A block, malformed decision or unavailable required check must not become an unprotected model call.
3. **Run the agent's own model.** The Gateway neither hosts nor proxies that call. Do not change the evaluated prompt or reuse its authorization for another interaction.
4. **Submit the completed interaction.** Forward the original receipt with matching agent, user, interaction and content bindings. The Gateway validates expiry, current protection context and single use before accepting the protected interaction.

8. Results must mean what they say

- An allowed evaluation is not permission to replay a receipt or ignore later policy changes. A context change may reject ingestion; do not silently mint replacement proof for already-generated content.
- **HTTP 202 means accepted for processing, not delivered.** Inspect the returned status, Purview processing and observability processing fields. Queued or failed work is not successful downstream delivery.
- Return structured, safe errors with a correlation ID and a permitted recovery action. Reject invalid identity bindings, unsupported input and stale proof explicitly.

Enforcement boundary: an external agent must honor returned decisions. The Gateway cannot undo a model call or a response the agent has already released.

Keep the integrations distinct

Telemetry transport, data protection and prompt attack checks are different jobs

9. Agent 365 telemetry

Forward supported activity and interaction telemetry directly through Microsoft's Agent 365 OpenTelemetry integration, with the correct tenant, agent identity and interaction correlation. No separate hosted monitoring service is required.

Document supported event types and retained fields. Report unsupported mappings explicitly. Distinguish local acceptance, queued work, export attempts, endpoint acceptance and observed downstream arrival.

10. Microsoft Purview content processing

Use the supported Purview content-processing/evaluation APIs, including **processContent** where applicable, with the intended agent and user context. Report the provider's actual decision and processing state without inventing enforcement.

- Let an authorized administrator connect the tenant, select the shared blueprint policy, choose sensitive-information types and thresholds, and explicitly review the policy change.
- Keep **Enforce, simulation and Off** distinct. Simulation is nonblocking and is not enforcement proof. A required enforcing check that cannot be completed must not return an unqualified allow.
- Explain that a blueprint policy may affect multiple agents. Per-agent protection choices remain explicit; changing a shared policy or completing a test must not silently enable every agent.
- Keep optional content collection separate from DLP, registration and telemetry. Provider offline/deferred processing does not establish synchronous response blocking.

11. Standalone Prompt Shields integration

Provide a separate prompt attack check through the supported Prompt Shields API/SDK. It can be enabled independently of Purview, applies before the model call, and does not require Microsoft model hosting. Surface the actual allow/block or service-error outcome.

Standalone does not mean offline: live evaluation requires the Microsoft endpoint and supported credentials. Never bypass a failed required check or report it as a clean prompt.

12. Honest state and appropriate data handling

Show **registration status, configured protection, current protection readiness and telemetry delivery** separately. Installed capability, a saved policy or an old successful test alone does not prove current enforcement.

Keep credentials, tokens and raw provider responses out of diagnostics. Do not put raw prompts or responses in routine logs, work queues or operational checkpoints. Content retained for an explicit product purpose belongs in access-controlled storage with defined retention; telemetry content disclosure must follow the selected configuration.

Protection outcomes explain four things: what happened, why it matters, what remains unverified, and the next permitted action. A technical Completed/Skipped log is not sufficient.

Prove the product, not the plumbing

Local-first development; focused real-provider acceptance; portable deployment

13. Minimum operational requirements

- **Portable hosting.** Support local/server or container deployment; change infrastructure through configuration and narrow adapters, not public APIs. Local fixtures must not require a cloud account.
- **Durable work.** Preserve accepted state and pending work across restarts. Handle duplicates safely; read back unknown provider outcomes before another write. A separate broker is optional; reliable recovery is not.
- **Secure operation.** Enforce server-side roles, tenant isolation, HTTPS, bounded inputs/timeouts and protected credentials. Expose useful health, operation status and safe audit history.
- **Limited provider coupling.** Isolate Microsoft authentication, APIs and any provider-imposed runtime limitation. A provider adapter must not dictate the operating system or cloud for the whole Gateway.

14. Observable acceptance scenarios

Scenario	Required demonstration
Registration	Register a real test agent, save its one-time key, complete the authorized Registry handoff, and verify the intended identity. Recover an interrupted result without creating a duplicate.
Telemetry	Submit supported events and confirm their arrival at the intended Microsoft destination under the correct agent identity, not just an accepted Gateway request.
Content checks	Exercise clean and blocking samples for Purview and Prompt Shields independently and together. Prove that blocks, expired receipts and required-check failures prevent an authorized model call.
Protection choices	Verify Off, simulation and enforcement behavior; preserve per-agent choices and explain shared policy scope. Reject invalid or reused receipts.
Failure and recovery	Interrupt provider calls and restart owned components. Retain accepted work, avoid duplicate external creation, and show failed or unknown results with a safe next action.
Portable operation	Run application and integration-fixture checks on the local server without cloud-hosted infrastructure. Promote the tested build to the chosen host and verify its environment-specific configuration.

15. Evidence and scope discipline

Use deterministic local fixtures for routine development and controlled live tenant tests for Microsoft authorization and behavior. Fixtures are not live-provider evidence. Disclose upstream preview, availability and support restrictions; this specification does not override them.

No general-purpose installer, broker migration, framework rewrite or infrastructure platform is required for core acceptance. Add operational complexity only for a demonstrated need.

Basis: the existing product brief, API contract and UX requirements, refined by the 01 October 2026 scope clarification. These are acceptance criteria, not completed checks. The repository milestone record remains the sole completion record.